Fakulteta za informacijske študije
Faculty of information studies

PROJECT ASSIGNMENT

Security Governance Pack of MediRaksha Diagnostic Center

Course: Organization Security

India, 03/05/2026

Athul Thuvattu Parambath

Table of Contents

1. Contents

1. Contents 2
2. Executive Summary 3
3. Organization Profile 3
4. Governance Objectives 3
5. Scope 4
6. Asset Register 4
7. Risk Method 5
8. Risk Register 6
9. Control Mapping 8
10. Policy Pack 9
11. Buisness Impact Analysis 10
12. Disaster Recovery Plan 10
13. Implementation Roadmap 11
14. Conclusion 12
15. Reference 12

2. Executive Summary

MediRaksha Diagnostic Center is a medium-sized healthcare diagnostic organization in Kerala, India, providing laboratory, radiology, ECG, screening, reporting, anfd billing services. The organization relies on patient data, diagnostic images, laboratory systems, medical IoT devices, cloud services, and staff endpoints, which makes confidentiality, integrity, and availability equally important.

The Security Governance Pack provides a realistic and defensible framework for protecting the organization. It includes an asset register, risk register, control mapping, policy pack, business impact analysis, and disaster recovery plan. The pack is designed to match the real operating environment of a diagnostic center and to show practical governance thinking rather than only technical design.

3. Organization Profile

Organization name: MediRaksha Diagnostic Center
Industry: Healthcare diagnostic and preventive screening
Location: Kerala, India
Size: 112 employees
Daily Volume: Approximately 110 per day
Facilities: Three floor covering reception, clinical services, laboratory, radiology, management, and IT operations.

The organization handles highly sensitive patient information, diagnostic images, test results, billing records, staff records, and operational data. Because diagnostic services depend on uptime and accurate records, the business cannot tolerate long outage, unauthorized data access, or tampering with clinical systems.

4. Governance Objectives

The governance objectives of this pack are:

- Protect patient confidentiality and diagnostic integrity.
- Ensure high availability of clinical and laboratory services.
- Reduce cyber, operational, and physical security risks.
- Define clear ownership for assets, risks, control, and recovery actions.
- Support compliance with healthcare security expectations and good governance practice. (Thapa Chhetri 2022)

5. Scope

This pack covers:

- Network infrastructure, firewalls, switches, wireless access points, and server room systems.
- Core applications such as LIS, PACS, patient portal, email, and billing systems.
- Endpoints such as workstations, laptops, tablets, printers, and mobile devices.
- Medical IoT and connected diagnostic equipment.
- Policies, monitoring, backup, incident response, and disaster recovery.

6. Asset Register

It is a list of important assests the organization owns or uses, such as servers.(What Is An IT Asset Register? 2024)

Asset ID	Asset Name	Category	Location	Owner	Sensitivity	Business Criticality
A-001	FortiGate NGFW	Network Security	Server room	IT Manager	High	Critical
A-002	Internet Modem 1	Network	Server room	IT Manager	Medium	High
A-003	Internet Modem 2	Network	Server room	IT Manager	Medium	High
A-004	Aruba Core Switch 1	Network	Server room	IT Manager	High	Critical
A-005	Aruba Core Switch 2	Network	Server room	IT Manager	High	Critical
A-006	ESXi Host	Server	Server room	IT Manager	High	Critical
A-007	ESXi Host 2	Server	Server room	IT Manager	High	Critical
A-008	PACS Server	Application/Server	Server room	Radiology Lead	High	Critical
A-009	LIS Server	Application/Server	Server room	Lab Manager	High	Critical
A-010	Patient Portal Server	Application/Web	DMZ	IT Manager	High	Critical
A-011	Email System	Cloud/Application	Cloud	Admin Officer	High	High
A-012	Billing System	Application/ Data	Accounts office	Accounts Manager	High	High
A-013	Patient Records Database	Data	Server room	Operations Manager	High	Critical
A-014	Imaging Archive Storage	Data	Server room	Radiology Lead	High	Critical
A-015	Test Result Database	Data	Server room	Lab Manager	High	Critical

A-016	Reception Workstations	Endpoint	Ground Floor	Reception Supervisor	High	High
A-017	Doctor Workstations	Endpoint	Clinical Floor	Medical Director	High	High
A-018	Lab Workstations Endpoints	Endpoint	Laboratory	Lab Manager	High	High
A-019	Admin Workstation	Endpoint	Third floor	Admin Officer	Medium	High
A-020	Staff Laptops	Endpoints	Various	IT Manager	High	High
A-021	Guest Wi-Fi APs	Network	Reception and floors	IT Manager	Medium	Medium
A-022	Clinical Wi-Fi APs	Network	Clinical zones	IT Manager	High	High
A-023	Medical IoT Devices	Medical Device	Ground/ First floor	Biomedical Engineer	High	Critical
A-024	CCTV NVR and Camera	Physical security	Security room	Operations Manager	Medium	Medium
A-025	Backup Storage Appliance	Backup	Server room	IT Manager	High	Critical
A-026	Cloud Backup Account	Backup/ Cloud	Cloud	IT Manager	High	Critical
A-027	UPS and Power Backup	Infrastructure	Server room	Operations Manager	Medium	High
A-028	Printer Fleet	Endpoint	Multiple floors	Admin Officer	Medium	Medium
A-029	HR Records	Data	Account office	Account Manager	High	High
A-030	Financial Records	Data	Account office	Accounts Manager	High	High

7. Risk Method

Risk scoring uses a 1 to 5 scale for likelihood and impact. Inherent risk is calculated as Likelihood x Impact. (Risk Assessment Methodologies Explained: Types, Examples, and How to Choose n.d.)

Score	Rating
1-5	Low
6-12	Medium
15-25	High

8. Risk Register

A central record of risks, including likelihood, impact, owner, and treatment plan.(Risk Register Examples for Cybersecurity Leaders n.d.)

Risk ID	Risk Description	Affected Assets	Likelihood	Impact	Score	Rating	Existing Control	Proposed Treatment	Risk Owner
R-001	Ransomware could encrypt LIS, PACS, and critical servers	A-006 to A015,A-025,A-026	4	5	20	High	Antivirus	EDR, segmentation, immutable backup, IR playbook	IT Manager
R-002	Phishing could compromise user accounts and expose patient data	A-011.A-016 to A-020	4	4	16	High	Basic Spam filter	Awareness training, MFA, secure email gateway	IT Manager
R-003	Unpatched servers could be exploited remotely	A-006,A-007,A-008,A-009,A-010	4	5	20	High	Manual Patching	Formal patch management and vulnerability scanning	IT Manager
R-004	Weak password use or password sharing could lead to unauthorized access	A-008 to A-017	4	4	16	High	Simple password policy	MFA,strong passwords, access reviews	Operations Manager
R-005	Misconfigured firewall rules could expose inernal services	A-001,A-010,A-013 to A-015	3	5	15	High	Vendor default config	Firewall rule review and change control	IT Manager
R-006	Guest Wi-Fi could be used as a pivot into internal system	A-021-A-022	3	4	12	Medium	Shared internet link	VLAN isolation and captive portal	IT Manager
R-007	Medical IoT devices may contain default credentials or unpatched firmware	A-023	4	5	20	High	Vendor managed devices	IoT network isolation and asset inventory	Biomedical Engineer

R-008	Data leakage could occur from lost or stolen laptops	A-020,A-029,A-030	3	5	15	High	Device login only	Full-disk encryption, remote wipe, asset tracking	IT Manager
R-009	Inside misuse could expose patient reports or images	A-008,A-009,A-13,A-014	3	5	15	High	Role-based access in some systems	Least privilege, logging periodic access review	Operations Manager
R-010	Backup failure could prevent recovery after incident	A-025,A-026	3	5	15	High	Daily backup job	Backup verification and quarterly restore tests	IT Manager
R-011	Power outage could interrupt clinical and server operations	A-001 to A-007, A-023,A-025,A-027	3	4	12	Medium	Daily backup job	Backup verification and quarterly restore tests	IT Manager
R-012	DDOS could make patient portal unavailable	A-010	3	4	12	Medium	Basic hosting protection	Web filtering, rate limiting, cloud protection	IT Manager
R-013	Insecure remote access could allow unauthorized entry	A-001,A-006 to A-010	3	5	15	High	VPN available	MFA on VPN access restrictions, logging	IT Manager
R-014	Poor log monitoring could delay detection of compromise	A-001 to A-010, A-023,A-024	4	4	16	High	Device logs only	Central SIEM and alerting rules	IT Manager
R-015	Staff could misuse USB devices and introduce malware	A-016 to A-020,A-023	3	4	12	Medium	Antivirus only	USB control and endpoint restrictions	IT Manager
R-016	Vendor compromise could affect PACS or LIS support access	A-008,A-009,A-010	3	4	12	Medium	Informal support	Vendor access policy and review	Managing Director
R-017	Printed reports could be exposed at reception or archive	A-028 and paper records	3	4	12	Medium	Staff handling	Secure printing and document retention rules	Admin Officer
R-018	CCTC or physical access failure could weaken security monitoring	A-024,A-001,A-025	2	4	8	Medium	CCTV installed	Physical access logs and maintenance checks	Operations Manager

9. Control Mapping

Linking each control to the risks or requirements it reduces.(How Control Mapping Ensures Cybersecurity Compliance n.d.)

Control ID	Control Description	Addesss Risks	Owner	Priority
C-001	Enforce multi-factor authentication for admin, remote, and cloud accounts	R-001, R-002, R-004, R-013	IT Manager	Critical
C-002	Implement role-based access control and periodic access review	R-004, R-009, R-016	Operations Manager	Critical
C-003	Deploy EDR and endpoint protection on all servers and workstations	R-001, R-003, R-015	IT Manager	Critical
C-004	Formal Patch and vulnerability management process	R-003, R-005, R-007	IT Manger	Critical
C-005	Network segmentation using VLANs for guest, clinical, lab, IoT, servers, CCTV, and DMZ	R-003, R-005, R-015	IT Manager	Critical
C-006	Immytable 3-2-1 backups with restore testing	R-001, R-010	IT Manager	Critical
C-007	Centralized SIEM logging and alerting	R-009, R-014, R-016	IT Manager	High
C-008	Secure VPN with MFA and restricted access	R-013	IT Manager	High
C-009	Security awareness and phishing training every 6 months	R-002, R-015	HR Officer	High
C-010	USB device control and removable media restriction	R-015	IT Manager	High
C-011	Secure print and Physical	R-017	Admin Officer	Medium

	document handling rules			
C-012	Firewall rule review, change management, and hardened configuration	R-005, R-012, R-013	IT Manager	Critical
C-014	Vendor access and third-party security management	R-016	Managing Director	High

10. Policy Pack

1. **Information Security Policy**
   MediRaksha shall protect patient, business, and employee information through confidentiality, integrity, and availability controls. All staff must protect credentials, report incidents, and follow approved procedures. Sensitive data may only be accessed for legitimate business purposes.

2. **Access Control policy**
   Access to systems shall be granted on a least-privilege basis. Shared accounts are prohibited unless formally approved. MFA is mandatory for privileged, remote, and cloud access. Access shall be reviewed periodically and removed promptly during off boarding.

3. **Acceptable Use Policy**
   Organizational devices, email, internet access, and storage resources shall be used only for authorized business purposes. Staff must not install unauthorized software, transfer patient data to personal accounts, or use unapproved removable media. Suspicious like and attachments must not be opened.

4. **Data Protection and Backup Policy**
   Critical data shall be encrypted in transit and at rest. Backup of patient records, LIS, PACS, billing, and configuration data shall follow the 3-2-1 principle where practical. Backup integrity shall be tested regularly, and retention shall match business and legal needs.

5. **Incident Response Policy**
   All incident or suspected incidents must be reported immediately. The organization shall follow the process of detection, containment, eradication, recovery, and review. Evidence shall be preserved, and communication shall be coordinated through management and IT.

6. **Remote Access Policy**
   Remote access is allowed only through approved VPN solutions with MFA. Access rights shall be limited to the minimum necessary. Remote sessions shall be logged, monitored, and reviewed when needed.(Technical Volume 1: Cybersecurity Practices for Small Health Care Organizations n.d.)

11. Business Impact Analysis

Process	Dependency	MTD	RTO	RPO	Impact of Failure
Patient registration	Workstation, network, patient records	8 hours	4 hours	1 hour	Delay service intake
Laboratory testing	LIS, lab devices, databases	4 hours	4 hours	30 minutes	Delays diagnosis and reporting
Radiology reporting	PACS, imaging archive, reporting systems.	4 hours	4 hours	1 hour	Clinical delay and revenue loss
Patient portal	Web app, internet, firewall	8 hours	4 hours	1 hour	Patient service interruption
Email and communication	Cloud email, endpoints	24 hours	8 hours	8 hours	Slower coordination and escalation
Backup and recovery	Backup appliance, cloud backup, admin access	Critical	4 hours	30 minutes	Restoration failure if backups are unavailable.

12. Disaster Recovery Plan

1. DR Objectives

The disaster recovery plan aims to restore critical diagnostic services quickly while preventing further damage and preserving evidence where necessary. Recovery priorities are based on patient safety, regulatory concerns, and business continuity.

2. Recovery Priorities

1. Network core, firewall, and internet connectivity.
2. Server infrastructure and authentication services.
3. LIS and patient records.
4. PACS and imaging archive.
5. Billing, email, and supporting systems.

3. DR Roles

Role	Responsibility
Managing Director	Declares disaster and approves external communication.
IT Manager	Leads technical recovery and security validation
Operations Manager	Coordinates business continuity and staff priorities
Lab Manager	Validate laboratory system restoration
Radiology Lead	Validate imaging and reporting restoration
Accounts Manager	Restores billing continuity and reconciliation
HR officer	Assists with communication and staff coordination.

4. DR Procedures

- Detect the incident using alerts, user reports, or monitoring tools.
- Isolate affected systems or network segments immediately.
- Assess impact and confirm whether restoration or fallback is needed.
- Restore from verified backups in the correct recovery order.
- Validate systems integrity before returning systems to production.
- Document the incident and conduct a post-incident review.

5. Backup Strategy

- Daily incremental backups for operational systems.
- Weekly full backups for critical servers and databases.
- Immutable offsite copies for ransomware resilience.
- Quarterly restore tests and documented evidence of success.(2019-AHIA-Crowe-Whitepaper.pdf n.d.)

13. Implementation Roadmap

Timeframe	Priority Actions
0-30 days	Approve policy pack, create asset inventory, enforce MFA, and review critical admin accounts.
31-60 days	Deploy EDR, tighten firewall rules, separated VLANs, formalize backup validation.
61-90 days	Conduct access review, run phishing training, enable SIEM logging, test restore.
90-180 days	Perform tabletop incident exercise, review vendor access, refine BIA and DR plan

14. Conclusion

This Security Governance Pack presents a realistic and defensible framework for MediRakhsa Diagnostic Center. The Package aligns assets, risk, controls, policies, and recovery planning into one coherent governance model. It is practical for a healthcare diagnostic environment and demonstrates clear reasoning, feasibility, and accountability.

15. Reference

- 2019-AHIA-Crowe-Whitepaper.pdf. n.d.
- How Control Mapping Ensures Cybersecurity Compliance. n.d. Retrieved May 3, 2026. https://swimlane.com/blog/cybersecurity-compliance-with-control-mapping/.
- Risk Assessment Methodologies Explained: Types, Examples, and How to Choose. n.d. Retrieved May 3, 2026. https://secureframe.com/blog/risk-management-methodologies.
- Risk Register Examples for Cybersecurity Leaders. n.d. Retrieved May 3, 2026. https://www.cybersaint.io/blog/risk-register-examples-for-cybersecurity.
- Technical Volume 1: Cybersecurity Practices for Small Health Care Organizations. n.d.
- Thapa Chhetri, Ishwor. 2022. “Cybersecurity And Governance, Risk And Compliance (GRC).”
- What Is An IT Asset Register? 2024. https://purplegriffon.com/blog/it-asset-register.